

Rapport Techniques de l'analyse de cette apk

Nom : GROSHENY Thibaut

EGEA Eric junior

MOUCHARD Ivann

Table des matières

INTRODUCTION	3
MÉTHODOLOGIE	3
FINDINGS ET PREUVES	3
RECOMMANDATIONS.....	6
CONCLUSION	7

INTRODUCTION

Dans le cadre d'une mission d'analyse de sécurité, nous avons procédé à une évaluation complète de l'application mobile Nickel (com.fpe.comptenickel, version 2.12.0, build 150), une application bancaire comptant plus de 5 000 000 de téléchargements sur le Play Store.

L'objectif de cette mission est d'identifier les vulnérabilités présentes dans l'application, de les documenter avec les preuves techniques associées, et de formuler des recommandations correctives adaptées.

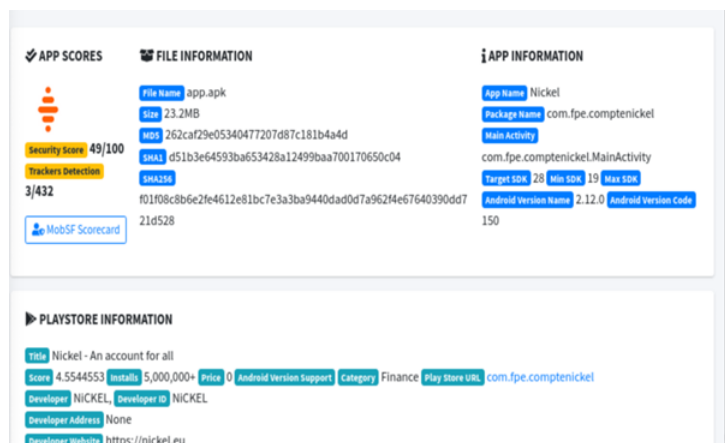
MÉTHODOLOGIE

L'analyse a été conduite en plusieurs étapes complémentaires : vérification de l'intégrité du fichier via empreinte SHA-256, analyse statique automatisée via MobSF, décompilation de l'APK avec Apktool, inspection manuelle du code source extrait, et tentative d'accès aux endpoints exposés.

FINDINGS ET PREUVES

3.1 Score de sécurité insuffisant

L'analyse MobSF attribue à l'application un score global de sécurité de **49/100**, révélant un niveau de protection moyen et plusieurs axes d'amélioration critiques.



3.2 Présence de trackers

Trois trackers ont été identifiés parmi les 432 référencés par MobSF. Leur présence dans une application bancaire soulève un enjeu de confidentialité significatif, dans la mesure où ces trackers peuvent collecter des données comportementales et d'usage à l'insu de l'utilisateur.

3.3 Version Android minimale obsolète

L'application déclare une compatibilité avec Android 4.4 (API niveau 19), une version qui ne bénéficie plus d'aucune mise à jour de sécurité. Les appareils fonctionnant sous cette version sont exposés à des vulnérabilités système connues et non corrigées.

3.4 Target SDK insuffisant

Le SDK cible est fixé à la version 28 (Android 9), ce qui empêche l'application de bénéficier des mécanismes de sécurité introduits dans les versions plus récentes du système Android, notamment les restrictions de réseau et les contrôles d'accès renforcés.



3.5 Exposition d'endpoints API sensibles

L'analyse du fichier strings.xml a révélé en clair trois endpoints d'API de production :

- <https://api.nickel.eu/customer-banking-api> — exposition de l'API bancaire, facilitant des attaques de reconnaissance ciblée.
- <https://api.nickel.eu/customer-authentication-api> — endpoint d'authentification exposé, potentiellement ciblable par des attaques de brute force ou des tentatives d'interception.
- <https://api.nickel.eu/personal-space-api> — accès potentiel aux données personnelles des utilisateurs via analyse des flux API.

```
(thibaut@thibautforensic) ~/apk_extract/app_dec/res/values
$ grep -iE "key|token|password|secret|api|url|http|auth" strings.xml
<string name="ACCOUNT_ENDPOINT">https://api.nickel.eu/customer-banking-api</string>
<string name="CUSTOMER_AUTHENTICATION_ENDPOINT">https://api.nickel.eu/customer-authentication-api</string>
<string name="PERSONAL_SPACE_API_ENDPOINT">https://api.nickel.eu/personal-space-api</string>
<string name="abc_capital_off">OFF</string>
<string name="abc_capital_on">ON</string>
<string name="catalyst_loading_from_url">Loading from %1$s.</string>
<string name="firebase_database_url">https://application-client-nickel.firebaseio.com</string>
<string name="google_api_key">AIzaSyBTgzvImsUfMWDa41PCrDWAj7dmyIDhUg</string>
<string name="google_crash_reporting_api_key">AIzaSyBTgzvImsUfMWDa41PCrDWAj7dmyIDhUg</string>
<string name="password_toggle_content_description">Show password</string>
<string name="path_password_eye">M12,4.5C7,4.5 2.73,7.61 1,12c1.73,4.39 6,7.5 11,7.5s9.27,-3.11 11,-7.5c-1.73,-4.39 -6,-7.5 -11,-7.5zM12,17c-2.76,0 -5,-2.24 -5,-5s2.24,-5 5,-5 5,2.24 5,-2.24,5 -5,5zM12,9c-1.66,0 -3,1.34 -3,3s1.34,3 3,3 -1.34,3 -3,-1.34,-3 -3,-3z</string>
<string name="path_password_eye_mask_strike_through">M2,4.27 L19.73,22 L22.27,19.46 L4.54,1.73 L4.54,1 L23,1 L23,23 L1,23 L1,4.27 Z</string>
<string name="path_password_eye_mask_visible">M2,4.27 L2,4.27 L4.54,1.73 L4.54,1 L73 L4.54,1 L23,1 L23,23 L1,23 L1,4.27 Z</string>
<string name="path_password_strike_through">M3.27,4.27 L19.74,20.74</string>
```

3.6 Exposition d'un backend Firebase

L'URL `https://application-client-nickel.firebaseio.com` est exposée en clair dans le code. Bien que la base de données Firebase est accessible mais actuellement protégée par des règles d'authentification et retourne une erreur 401 Unauthorized, une mauvaise configuration future de ces règles pourrait exposer des données critiques telles que les informations utilisateurs ou les transactions financières.

```
(thibaut@thibautforensic)-[~/apk_extract]
$ curl -i https://application-client-nickel.firebaseio.com/.json
HTTP/1.1 401 Unauthorized
Server: nginx
Date: Tue, 28 Apr 2026 10:53:38 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 36
Connection: keep-alive
Access-Control-Allow-Origin: *
Cache-Control: no-cache
Strict-Transport-Security: max-age=31556926; includeSubDomains; preload

{
  "error" : "Permission denied"
}
```

3.7 Clé API Google exposée en clair

Deux clés sensibles ont été découvertes dans `strings.xml` :

- `google_api_key` : `AlzaSyBTgztlmsUfMWDa41PCrDWAj7dmylDhUg`
- `google_crash_reporting_api_key` : valeur identique

Ces clés, intégrées en dur dans le code, peuvent être extraites par tout acteur malveillant ayant accès à l'APK. Leur exploitation pourrait permettre un abus de services Google associés, un dépassement de quotas ou une extraction de données liées au compte.

3.8 Recompilation et re-signature de l'APK

Il a été possible de décompiler, modifier et re-signer l'application en utilisant Apktool et apksigner. L'APK re-signé (rebuilt_signed.apk) est reconnu comme valide par le système Android avec les schémas de signature v1, v2 et v3. Cela démontre l'absence de mécanisme de vérification d'intégrité ou d'anti-tampering au sein de l'application.

```
(thibaut@thibautforensic)-[~/apk_extract]
$ apksigner sign \
--ks mykeystore.jks \
--ks-key-alias myalias \
--out rebuilt_signed.apk \
app_aligned.apk
Keystore password for signer #1:
```

```
(thibaut@thibautforensic)-[~/apk_extract]
$ apksigner verify --verbose rebuilt_signed.apk
Verifies
Verified using v1 scheme (JAR signing): true
Verified using v2 scheme (APK Signature Scheme v2): true
Verified using v3 scheme (APK Signature Scheme v3): true
Verified using v3.1 scheme (APK Signature Scheme v3.1): false
Verified using v4 scheme (APK Signature Scheme v4): false
Verified for SourceStamp: false
Number of signers: 1
```

RECOMMANDATIONS

R1 — Rehausser la version Android minimale : Relever le minSdkVersion à un niveau maintenu activement (API 26 minimum), afin d'éliminer l'exposition aux vulnérabilités des systèmes obsolètes.

R2 — Mettre à jour le Target SDK : Cibler le SDK Android le plus récent disponible afin de bénéficier de l'ensemble des protections système actuelles.

R3 — Supprimer les endpoints du code client : Les URLs d'API ne doivent pas figurer en clair dans les ressources de l'application. Elles doivent être gérées côté serveur ou chargées dynamiquement via un mécanisme sécurisé.

R4 — Révoquer et remplacer les clés API exposées : La clé AlzaSyBTgztlmsUfMWDa41PCrDWAj7dmylDhUg doit être révoquée immédiatement et remplacée. Les secrets ne doivent jamais être intégrés en dur dans le code source ou les ressources de l'APK.

R5 — Sécuriser les règles Firebase : Auditer et durcir les règles de sécurité Firebase afin de garantir qu'aucune donnée sensible ne puisse être exposée en cas de mauvaise configuration, même temporaire.

R6 — Mettre en place un mécanisme anti-tampering : Implémenter une vérification d'intégrité de l'APK à l'exécution pour détecter toute modification ou re-signature non autorisée.

R7 — Réduire la surface de tracking : Justifier la présence de chaque tracker et, pour une application bancaire, envisager leur suppression ou leur remplacement par des solutions respectueuses des données personnelles.

CONCLUSION

L'application Nickel présente plusieurs vulnérabilités de sécurité significatives, notamment l'exposition de secrets techniques, l'absence de protection contre la recompilation et un niveau de SDK insuffisant. Compte tenu du volume d'utilisateurs et de la nature des données traitées (IBAN, transactions, données d'authentification), ces failles représentent un risque élevé.